

RP21

Risk Management Manual

S&T AG	
Area of application:	S&T Group
Author:	Monika Hieblinger
Version:	V 1.0
Created on:	03.07.2007
Last change on:	-
Last change done by:	-
Authorized by/on (eMail or original signature is laid out at the QM)	Martin Bergler / 16.08.2007

Subject / Object

The goal of Risk Management is to achieve

- better identification of opportunities and threats
- increased risk awareness of all S&T employees;
- a more confident and transparent basis for decision-making and planning;
- protection against loss of information, assets and image;
- improved stakeholder confidence and trust.

Responsible for local implementation

Managing Directors

Description

Table of Contents

1	Risk and Opportunity	3
2	What is Risk Management?	3
3	Why should I manage risks?	3
4	Risk Management Principles	3
4.1	Only identified risks can be managed	3
4.2	Risks can hardly be avoided, but they are manageable	4
4.3	Managing risk is everyone's business but it starts at the top	4
4.4	Open, honest and effective communication	4
4.5	Risk Management has to be improved continuously	4
5	How do I manage risks?	4
5.1	The Risk Management Cycle	4
5.2	Establish the framework	5
5.3	Risk Identification	5
5.4	Risk Evaluation	6
5.5	Risk Treatment	7
5.5.1	Avoidance	8
5.5.2	Reduction	8
5.5.3	Sharing	8
5.5.4	Acceptance	8
5.6	Risk Reporting	8
5.7	Risk Monitoring	9
6	S&T Risk Management Process	9
6.1	Roles and Responsibilities	9
6.2	S&T Risk Management Process	11
6.2.1	Formal Risk Management Process	11
6.2.2	Strategic Risk Management Process	13

1 Risk and Opportunity

Risk is regarded as

- uncertain future event that could influence the achievement of the organization's strategic, operational and financial objectives,
- unused chance,
- potential asset for the company and implies growth potential.

In all types of undertaking, there is the potential for events and consequences that constitute opportunities for benefit (upside) or threats to success (downside). Risk Management considers risks from both perspectives. Events representing risks require management's risk assessment and response. Opportunities are channeled back to the strategy or objective-setting process by the management, formulating plans to seize these opportunities.

2 What Is Risk Management?

Risk management is:

- a continuous and developing process
- applied by people across the company, at every level and unit
- applied in strategy setting and
- designed to identify events that may affect the company and to manage risk within its risk appetite
- able to provide reasonable assurance to the company's management and board of directors regarding achievement of the company's objectives.

Good risk management will be a routine activity and will therefore be integrated into general management activity.

3 Why should I manage risks?

We all manage risk every day, although we might not be aware of it. To use our resources effectively and to avoid blocks which stop us from getting to where we are headed, we have integrated risk management processes into our activities as a matter of course.

But managing risks systematically will help you to make effective decisions, as risk management illustrates the upside and downside of each new venture. You can then direct budget and resources towards risks which impact on strategic and operational objectives.

Through practicing risk management you can improve your:

- knowledge and understanding of your exposure to risk
- targeting of resources to key risk areas
- control over costs and processes
- protection of assets.

4 Risk Management Principles

4.1 Only identified risks can be managed

The focus of good Risk Management is the identification and treatment of risks. It increases the probability of success and reduces both the probability of failure and the uncertainty of achieving the company's objectives.

4.2 Risks can hardly be avoided, but they are manageable

Risk Management is not risk avoidance. It is simply a practice of systematically selecting cost effective approaches for minimizing the effect of threat realization to the organization. The objective is to identify the key risks to ensure that adequate focus is given to important issues. All risks can never be fully avoided or mitigated simply because of financial or practical limitations. Therefore all organizations have to accept some level of residual risk.

4.3 Managing risk is everyone's business but it starts at the top

Employees at all levels are committed to work on the achievement of the company's goals and to prevent harm to the company. Employees identify and manage the risks they can and have to report upwards existing or imminent risks they cannot manage to their Manager, the Managing Director or directly to the Risk Manager. Country Management is primarily responsible for identifying risks and managing them as well as the implementation and maintenance of sound risk management processes.

4.4 Open, honest and effective communication

Damages or identified risks must be communicated immediately, directly and honestly. Effective communication should occur in a broader sense, flowing down, across and up the entity. It is important to recognize risks at an early stage, not to find someone to blame!

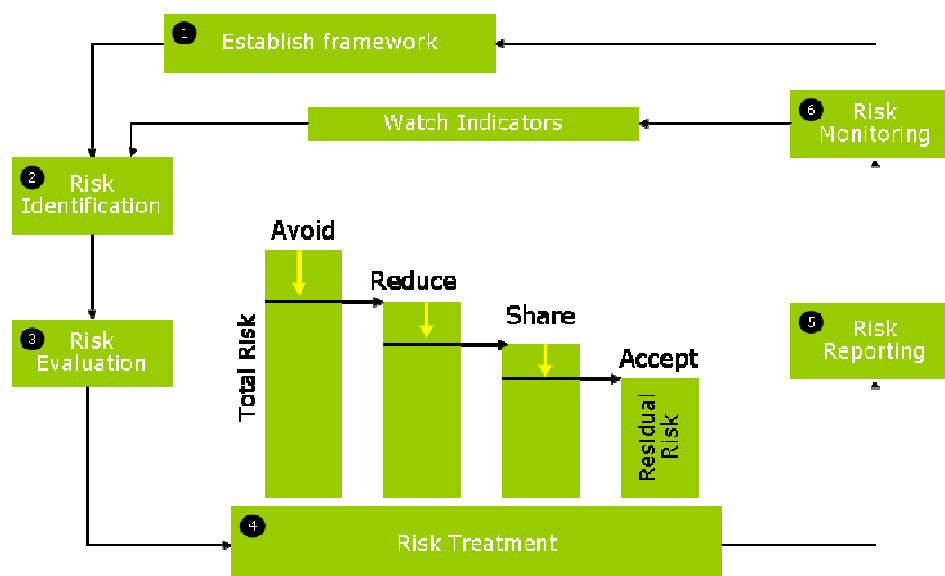
4.5 Risk Management has to be improved continuously

Risk Management is a continual and developing process. It should address methodically all the risks surrounding the company's activities past, present and in particular, future.

5 How do I manage risks?

5.1 The Risk Management Cycle

Risk management is essential to achieve business objectives and effective governance. After first evaluation of the risk portfolio risk management shall be established as an organizational strength that is integrated with management practices and reporting cycles. The risk management cycle consists of following phases:



5.2 Establish the framework

The executive board has the overall responsibility for ensuring that risks are managed. It defines the corporate risk management framework including principles, procedures and responsibilities outlined in this risk management manual.

Risk management has to be monitored to assess the presence and the functioning of its process and the quality of the performance over time. Monitoring is done through ongoing activities and a separate evaluation by Internal Audit. It ensures that risk management continues to be applied at all levels and across the company.

5.3 Risk Identification

It is important to identify, describe and understand the extent to which potential events might impact the achievement of objectives. Potential exposures are summarized in the “**Risk List**” where risks are categorized into risk groups and further into four main risk types. The risk list is not exhaustive, but rather a “living document” as risks may change when business is changing.

<i>Risk Types</i>	<i>Risk Groups</i>
1. Global Risks	1.1 Strategic Risks
	1.2 External Influence Risks
2. Client- and Sales Specific Risks	2.1 Client Relationship Risks
	2.2 Growth and Market Risks
	2.3 Product Risks
	2.4 Risks Structural Changes
	2.5 Financial Sales Risks
3. Performance and Process Oriented Risks	3.1 Research and Development
	3.2 Stock Risks
	3.3 Procurement Risks
	3.4 Production and Project Risks
	3.5 Quality Risks
4. Operational Risks	4.1 Human Resources Risks
	4.2 Cash Flow Risks
	4.3 IT Risks
	4.4 Legal Risks
	4.5 Corporate Governance Risks

When identifying risks go through the “Risk List” and ask for each item:

- **What can go wrong?**
- **How can it go wrong?**
- **Do we have existing and adequate controls?**

Key considerations when identifying risks:

- Be careful not to identify an issue as a risk. Issues are concerns that cannot be avoided, such as an unrealistic timescale for delivering a project, whereas a risk may not actually materialize.

- The risks identified should be meaningful to your operation and realistic – i.e. not the risk of an asteroid hitting your office.
- Think about existing policies or missing controls that have not been identified.
- Don't forget to identify opportunities that could be worth taking some risk to help achieve your objectives.

You can identify risks through:

- (local) management meetings
- brainstorming
- history, failure analysis
- incidents or complaints
- audit inspections
- organizational experience
- personal experience
- process analysis
- SWOT analysis etc.

If you experience that there is something to be added to the "Risk List" please inform the Risk Manager at S&T AG who will extend the list.

5.4 Risk Evaluation

After identifying the range of risks, the next step is to separate minor risks from major and to begin to prioritize. The question of "how risky" a risk is determined by evaluating two perspectives:

- Extent of loss (damage)
- Probability of occurrence

Probability of occurrence represents the possibility that a given event will occur while the extent of loss represents its effect should it occur. Both perspectives have to be qualified in a 3-stage scale: low (1), medium (2) or high (3):

	Extent of loss		
Risk Classes	Low = 1	Medium = 2	High = 3
Costs (€)	x < 250.000	250.000 < x < 2.000.000	x > 2.000.000
Delay	Minimal Delay	Overall delay of 10-20%	Delay > 20%
Functionality	Minimal functionality loss	Significant functionality loss	Functionality is unacceptable for client
Quality	Minimal quality loss	Quality reduction demands client approval	Quality is unacceptable for client

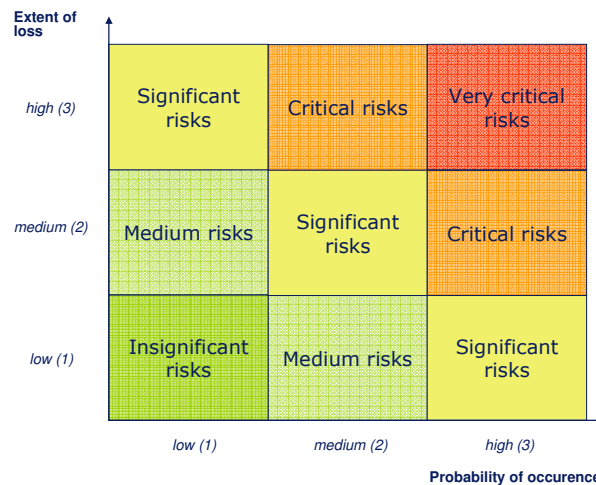
	Probability of occurrence		
	Low = 1	Medium = 2	High = 3
	Less than once a year	Once or several times a year	Once or several times a month

The degree or level of risk can be measured according to the expression:

$$\text{Risk} = \text{Extent of loss (damage)} * \text{Probability of occurrence}$$

Risks are assessed on both a current and a residual basis. First, risk evaluation is applied to current risk [**actual (gross) risk**] – the risk to the entity in absence of any actions management might take to alter either risk's probability and/or consequences. Once risk responses (actions) have been developed, management then determines residual risk [**target (net) risk**] – the remaining risk after management's actions to alter the risk's probability and/or extent of loss.

The matrix below combines extent of loss and probability of occurrence to produce risk levels. The main focus must be on very critical, critical and significant risks!

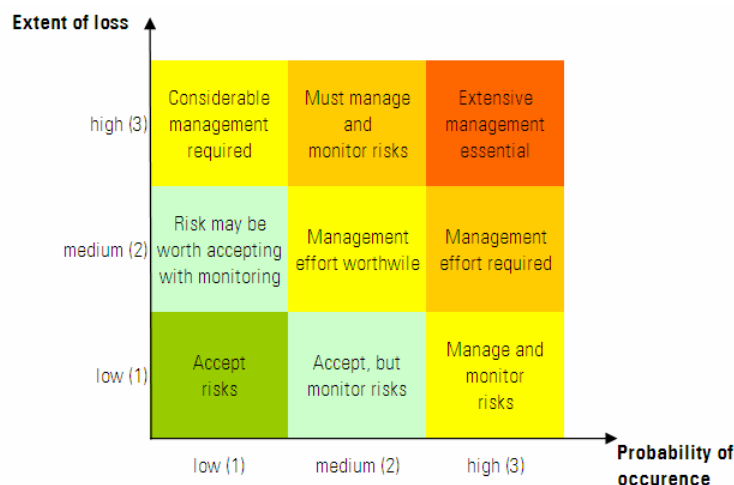


5.5 Risk Treatment

When assessing the level of risks, you are deciding whether they are acceptable or unacceptable risks. A risk is called "acceptable" when it is not going to be treated i.e. actual risk ≤ 2 : insignificant, medium risks. Unacceptable risks have to be treated in some way i.e. actual risk ≥ 3 : very critical, critical and significant.

The Managing Director (risk owner) shall develop risk response options (**actions**) for unacceptable risks and consider their effect on probability and extent of loss expressed as "target probability" and "target damage".

The following risk response matrix gives an overview of **treatment options** for the different risk levels:



A number of options are available to manage risks:

5.5.1 Avoidance

Avoiding the risk involves deciding to:

- stop the activity
- choose an alternative, a more acceptable activity
- choose an alternative, a less risky methodology or process

5.5.2 Reduction

Actions can reduce the **probability of occurrence**, the **extent of loss (damage)** or both through:

- preventive actions
- corrective actions
- process controls

5.5.3 Sharing

Transfer or share a portion of a risk through

- contractual transfer
- exclusion clauses
- insurance
- hedging
- outsourcing
- partnerships
- subcontracting

5.5.4 Acceptance

No action is set to affect probability and/or damage, just monitoring.

5.6 Risk Reporting

The data from the "Risk List" (xls) are imported into the Cognos Metric Studio for further analyzing and reporting. There are following reports regarding risks and related responses per country:

- Top 5 Risks
- Status Report
- Actions Report
- Trend Report
- Charts

Top 5 Risks: Status of the 5 most significant risks (quarterly)

Status Report: Risk portfolio that summarizes all the faced and future risks (half-yearly)

Actions Report: Describes how particular risks will be handled – what, when, by who will be done to minimize the consequences and a finish date (half-yearly)

Trend Report: Compares prior periods actual risks with current period actual risks and indicates a trend (half-yearly)

Chart: Displays at a glance the number of very critical and insignificant risks in the 3 x 3 matrix (half-yearly) for the actual risk status (before actions) and target risk status (after actions)

5.7 Risk Monitoring

Changes can impact existing risks and give rise to new risk. Constant watching of indicators and warning signs will help to reveal new risks. Through monitoring, one can identify if new risks are appearing on the radar or if identified risks are dropping from the radar. Outputs of the risk monitoring are used to update the risk list.

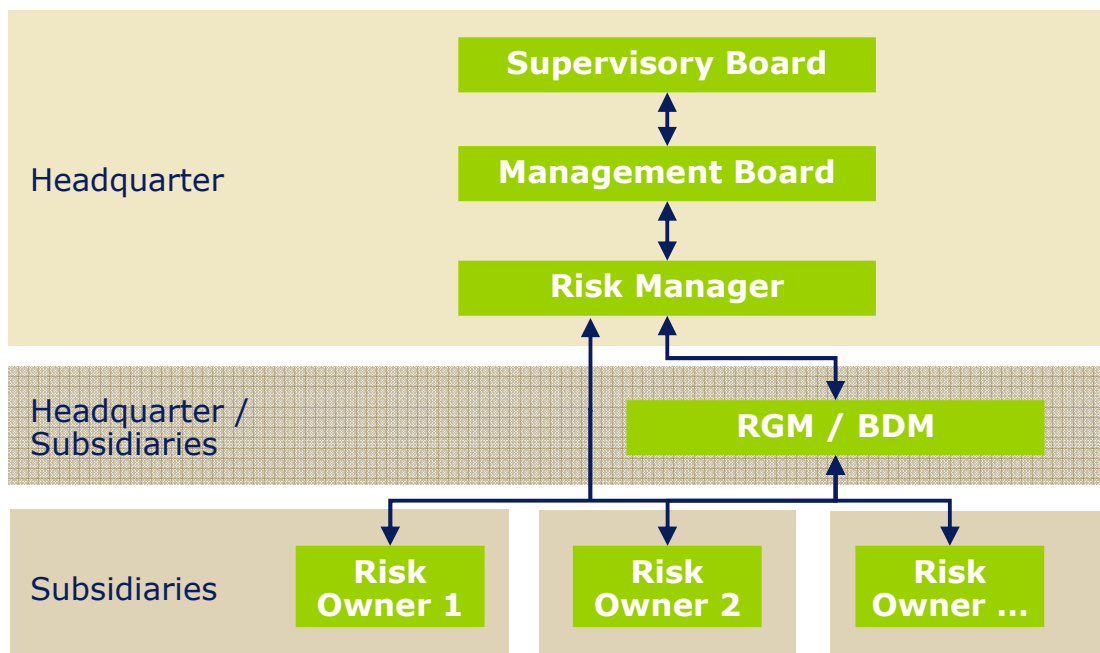
Top 5 risks shall be updated quarterly, the full risk list half-yearly:

- To evaluate whether previously selected actions/controls are still applicable and effective, and
- To evaluate the possible risk level changes in the business environment.

The Risk Owners, in cooperation with the Risk Manager, are responsible for monitoring risks and actions.

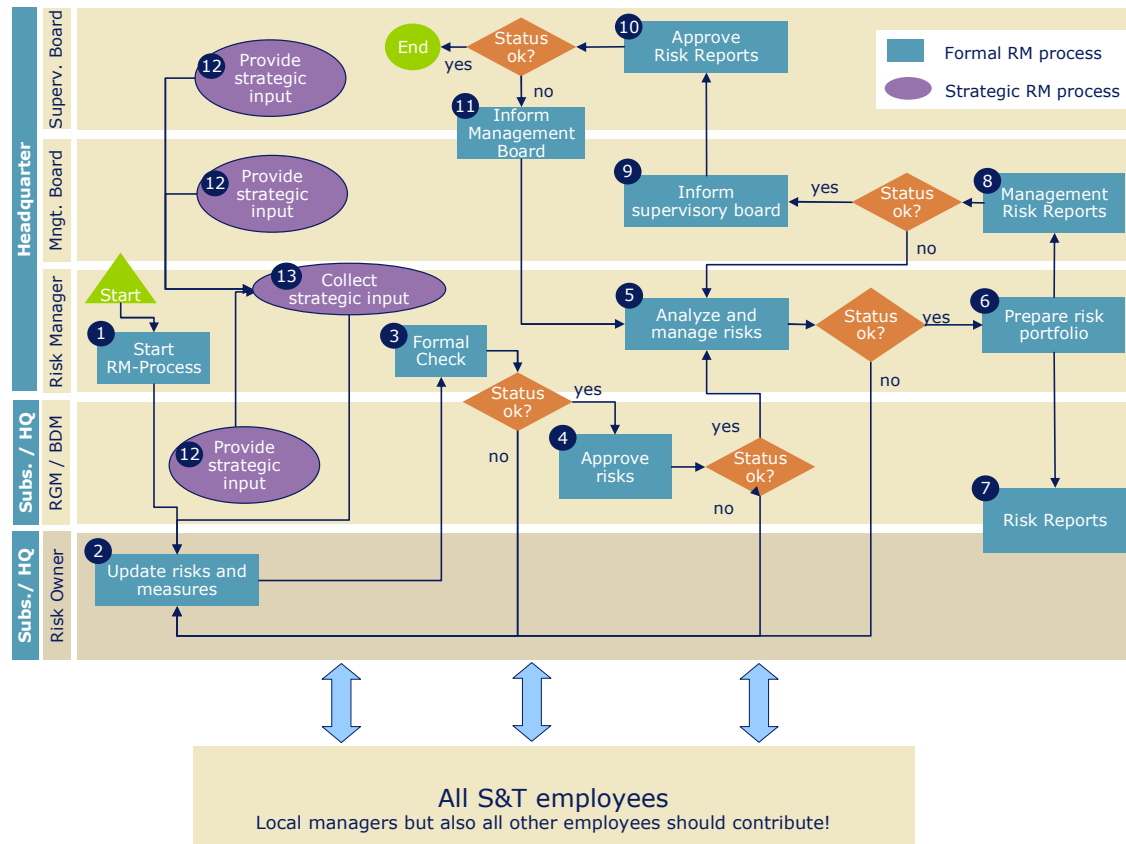
6 S&T Risk Management Process

6.1 Roles and Responsibilities



Role	Description	Location
Supervisory Board:	The Supervisory Board has to control the risk portfolio and to supervise the trends and critical risks once a year. Provides strategic input once a year.	HQ
Management Board:	The Management Board (CEO, CFO) has to control the risk portfolio and to supervise the trends of critical risks on a quarterly basis. It has to verify the risk portfolio of the company group and to inform the supervisory board about the actual status and the development of risks. Provides strategic input once a year.	HQ
Risk Manager:	The Risk Manager is responsible for the whole risk management process within the company group. The risk manager starts the process, manages the risks of the headquarter and supervises the risk management process in the subsidiaries. The risk manager performs the analyses of the company risks and informs the Managing Board about the risk portfolio and relevant developments.	HQ
RGM/BDM:	The Regional General Manager (RGM) has to review the risk register provided by the Risk Owner (on a quarterly basis). After the verification of risks, the risk portfolio can be further processed by the Risk Manager. The RGM has a second role within the risk management process. Together with the Business Development Manager (BDM) he provides strategic input regarding the development of possible risks in the region/individual countries/ business units to the Risk Owners. The strategic input regarding risks has to be provided once a year (preferably during the business planning phase in Q3/Q4).	HQ, Subsidiaries
Risk Owner:	The Risk Owner is the Managing Director of a country. Risk Owners are responsible for ensuring that controls, further actions and specific monitoring of risks are carried out in a timely manner, but they are not necessarily the person responsible for performing actions. Risk Owners provide the updated risk register to the RGM for verification and to the Risk Manager for further processing (quarterly "Top 5 Risks" / half-yearly full "Risk List").	Subsidiaries
Internal Auditor:	Plays an important role in monitoring and reviewing the risk management process and recommends improvements. Provides also input for updating risks and measures based on executed audits in the subsidiaries.	HQ

6.2 S&T Risk Management Process



6.2.1 Formal Risk Management Process

Step	Description	Responsible
1 Start RM-Process	The risk owners in the subsidiaries get informed that the risk management process is started and that they have to provide information about the risk portfolio until a defined due date. (four times a year: Q1, Q2, Q3, Q4).	Risk Manager
2 Update risks and measures	The risk owners in the subsidiaries have to check the risks they are responsible for regarding completeness and timeliness. If necessary, the evaluations of the risks have to be updated. The defined measures/actions have to be checked regarding their fulfilment and their appropriateness. Strategic input from the risk manager provided once a year has to be considered regarding the update of the risk list and measures.	Risk Owner
3 Formal Check	Risk Manager has to check input from risk owners with regard to plausibility and completeness of data. The risk list is then provided to the RGM for verification.	Risk Manager

Step	Description	Responsible
4 Approve risks	After the verification of the risk portfolio by the RGM the risks are provided to the Risk Manager in the headquarter for further processing.	RGM
5 Analyze and manage risks	In the headquarter the risks approved by the Regional General Manager get aggregated with the risks of the other subsidiaries. The provided risk portfolio for the company group is then analyzed and managed by the Risk Manager (evaluation of risks, measures, due dates, responsibilities). Additional input from the Management Board, Internal Audit and Supervisory Board is used to update the analyzes and measures.	Risk Manager
6 Prepare risk portfolio	Based on the risk portfolio of the company group reports are generated to illustrate the risk situation for the Risk Owners, Regional General Managers, Management Board and Supervisory Board.	Risk Manager
7 Risk reports	Risk reports per country are made available to the Risk Owner of the respective country. The Regional General Managers receive the risk reports of those countries they are responsible for.	Risk Manager
8 Management Risk Reports	The risk portfolio of the whole company group is distributed to and checked by the Management Board.	Management Board
9 Inform Supervisory Board	The Management Board should provide oversight and discuss with the supervisory board the group's risk situation.	Management Board
10 Approve Risk Reports	The risk portfolio of the company group is discussed and approved by the Supervisory Board. The risk management process ends here. The next risk management process has to be initiated by the Risk Manager.	Supervisory Board
11 Inform Management Board	The Supervisory Board informs the Management Board if it does not approve the risk portfolio of the company group. The Management Board will forward this information to the Risk Manager for further processing.	Supervisory Board

6.2.2 Strategic Risk Management Process

Step	Description	Responsible
12 Provide strategic input	Once a year (preferably during the business planning phase in Q3/Q4) the Supervisory Board, the Management Board, the Regional General Managers together with the Business Unit Managers provide an input to the Risk Manager, regarding their view on the strategic development of possible risks in the region / country / business unit.	Supervisory Board, Management Board, RGM, BUM
13 Collect strategic input	The Risk Manager collects strategic input and updates the risk list when necessary. This input is further used by the Risk Owners as basis for the evaluation of their risk portfolio.	Risk Manager